

匿名网络技术与安全对抗研究

梁峻玮 田丰睿 李青宇
PB23071341 PB23071318 PB23071316

2026 年 5 月 28 日

摘要

在此撰写摘要。

1 引言

1.1 研究背景与动机

随着 TLS、HTTPS 等加密协议的普及，网络通信内容的机密性已经在很大程度上得到保护。然而，内容加密并不等价于通信隐私的充分保护。即使攻击者无法解密具体载荷，通信双方的网络位置、连接时间、包长分布、方向序列、突发模式以及访问频率等元数据仍可能暴露用户行为和通信关系。Sasy 和 Goldberg 将这类问题概括为元数据保护通信系统（metadata-protecting communication systems, MPCs）的核心目标，即不仅要隐藏消息内容，还要尽可能削弱攻击者对发送者、接收者及二者关联关系的推断能力 [1]。从这一角度看，匿名网络并不是传统加密通信的替代品，而是在内容机密性之外进一步缓解通信关系泄露和流量侧信道的一类协议与系统机制。

匿名通信研究最早可以追溯到 Chaum 提出的 Mix 网络。该工作通过批处理、重排序和级联 Mix 打破输入消息与输出消息之间的对应关系，奠定了匿名通信对抗流量分析的基本范式 [2]。随后，洋葱路由进一步将匿名通信推向低延迟交互式场景：Tor 作为第二代洋葱路由系统，通过多跳电路、分层加密、目录服务和汇合点机制，在可用性、效率和匿名性之间作出工程化折中，成为目前最具代表性的匿名通信网络之一 [3]。这种设计使得单个中继难以同时获知通信源和通信目的，但低延迟交互式通信也保留了较多可观测的流量形状特征，为后续的网站指纹识别、流量相关和去匿名化攻击留下了空间。

近年来，匿名网络研究的重点逐渐从单纯构造匿名通信机制，转向围绕真实部署环境下的攻防对抗、可用性约束和安全边界展开。一方面，攻击技术不断利用加密流量中的时序和方向模式提升推断能力。例如，Shen 等人针对 Tor 网站指纹防御提出鲁棒流量表示方法，说明已有填充类防御仍可能保留可被学习的结构性泄露 [4]；Zhao 等人进一步将 Tor 指纹攻击推进到细粒度网页级识别，表明攻击目标已经从“访问了哪个站点”扩展到“访问了站点中的哪个页面” [5]。另一方面，真实环境评估也逐渐受到重视，Jansen 等人通过真实 Tor 流量轨迹构建数据集，指出以往基于合成数据的评估可能难以充分反映开放世界中的访问分布、基础率和会话复杂性 [6]。这些工作共同表明，匿名网络的安全性不能仅在理想化协议模型中讨论，而必须结合真实流量、真实用户行为和实际部署约束进行分析。

匿名网络的另一重要特征是其双重用途。一方面，它为新闻工作者、研究人员、政治异见者和普通用户提供了规避审查、保护访问隐私和降低追踪风险的工具；另一方面，匿名性也可能被恶意行为者利用，用于隐藏钓鱼站点、暗网服务、命令与控制（Command and Control, C&C）基础设施以及僵尸网络运营者的真实位置。因此，匿名网络研究不仅需要回答“如何提升匿名性”，还必须进一步讨论“如何在不动摇合法匿名性的前提下识别和治理滥用”。这正构成了本文从匿名网络基础、Tor 网络攻防到僵尸网络匿名化与检测进行系统综述的主要动机。

1.2 研究范围与综述思路

本文围绕“匿名网络、Tor 网络与僵尸网络”这一主题展开调研，但并不试图覆盖所有隐私增强技术或所有匿名通信系统，而是聚焦于与网络安全协议最密切相关的三类问题：匿名通信机制如何隐藏通信关系，Tor 网络在真实部署中面临哪些流量分析与去匿名化威胁，以及僵尸网络等恶意活动如何利用匿名网络隐藏基础设施。换言之，本文关注的核心并非单纯的“匿名通信技术介绍”，而是匿名网络在协议设计、流量侧信道、攻防对抗和滥用检测之间形成的系统性安全问题。

在匿名通信基础方面,本文首先从元数据保护通信系统的视角出发,梳理匿名通信所试图保护的对象,包括发送者身份、接收者身份、通信双方关联关系以及多次通信行为之间的不可链接性 [1]。在此基础上,本文比较 Mix 网络、洋葱路由和 DC-Nets 等代表性技术路线。Chaum 提出的 Mix 网络通过批处理和重排序降低输入、输出消息之间的可链接性 [2],而 Tor 所代表的低延迟洋葱路由则通过多跳电路和分层加密支持交互式匿名访问 [3]。两类技术分别体现了匿名通信设计中的不同取舍:前者通常具有更强的流量混淆能力,但延迟和可部署性成本较高;后者更适合 Web 浏览等交互式场景,却更容易暴露包长、方向和时序等可被学习的流量特征。

在 Tor 网络攻防方面,本文重点讨论低延迟匿名网络在真实环境下面临的攻击与防御问题。近年来,网站指纹识别、流量相关攻击和针对洋葱服务的去匿名化技术不断发展,使得攻击者即使无法解密通信内容,也可能通过加密流量的形状特征推断用户访问目标或关联通信双方。与此相对应,流量填充、流量整形、对抗式防御和差分隐私机制被用于削弱流量侧信道,但这些防御通常会引入额外带宽、延迟或部署复杂性。因此,本文在综述 Tor 攻防技术时,不仅关注具体攻击或防御方法本身,也关注其威胁模型、评估数据集、现实可部署性和安全一性能权衡。

在僵尸网络匿名化与检测方面,本文将 Tor 等匿名网络视为一种可能被滥用的基础设施,分析其在隐藏 C&C 服务器、规避追踪和提高恶意活动韧性方面的作用。与传统僵尸网络检测相比,匿名网络环境下的检测问题更加复杂:防御者既需要识别恶意流量和匿名化 C&C 行为,又必须避免破坏合法用户的匿名通信需求。因此,本文将僵尸网络部分置于“匿名网络双重用途”的框架下讨论,重点分析隐私保护与安全治理之间的张力,而不是泛泛介绍僵尸网络分类或恶意软件传播过程。

综上,本文的综述思路可以概括为“技术基础—典型系统—恶意滥用—系统讨论”。首先,第二章介绍匿名网络的基本目标、威胁模型和主要技术路线,为后续分析提供概念基础;其次,第三章以 Tor 网络为核心,系统梳理其架构、攻击面和攻防演进;再次,第四章讨论僵尸网络如何利用匿名网络隐藏基础设施,以及匿名环境下检测与治理的挑战;最后,第五章从系统化角度总结匿名网络攻防中的核心矛盾,包括匿名性与可追责性、低延迟可用性与抗流量分析能力、滥用检测与用户隐私保护之间的权衡。

1.3 论文组织结构

本文其余部分组织如下。第二章介绍匿名网络技术基础,首先界定匿名通信所保护的对象和典型威胁模型,随后梳理 Mix 网络、洋葱路由、DC-Nets 等代表性技术路线,并从匿名性、时延、带宽开销和可部署性等维度分析不同机制之间的权衡关系,为后续讨论 Tor 网络攻防提供概念基础。第三章以 Tor 网络为核心,首先介绍其系统架构、通信电路和洋葱服务机制,随后围绕网站指纹识别、流量相关攻击、带宽操纵攻击和洋葱服务去匿名化等方向总结近年来的攻击技术进展,并进一步分析流量填充、流量整形和协议层防御等对抗方法的有效性与局限性。

第四章讨论僵尸网络对匿名网络的利用及其检测问题。该章首先概述僵尸网络的基本架构与 C&C 通信模式,然后重点分析恶意活动如何借助 Tor 洋葱服务隐藏控制基础设施,并从流量特征、行为模式和机器学习检测等角度梳理匿名环境下的检测方法及其挑战。第五章在前述分析基础上进行系统化讨论,进一步总结匿名网络、Tor 网络与僵尸网络之间的技术关联,提炼匿名通信系统面临的核心矛盾,包括低延迟可用性与抗流量分析能力之间的矛盾、隐私保护与滥用治理之间的矛盾,以及真实部署评估与理想化安全模型之间的差距。第六章对全文进行总结,并展望匿名网络攻防研究在真实流量测量、可部署防御、隐私保护型滥用检测和安全治理机制等方面的未来发展方向。

2 匿名网络技术基础

匿名通信技术旨在保护用户的通信隐私和身份匿名性,使得攻击者难以将网络流量与特定用户联系起来。本章介绍匿名网络的核心概念、主要技术及其发展趋势。

2.1 匿名网络核心概念

2.1.1 匿名性定义与度量

匿名性 (Anonymity) 是指在通信过程中隐藏参与者身份的能力。在匿名通信系统中,攻击者即使能够观察网络流量,也无法确定消息的发送者或接收者。匿名性的强度通常通过匿名集 (Anonymity

Set) 的大小来度量——匿名集越大, 攻击者需要从中识别真实用户的难度越高。

然而, 传统的匿名性度量方法存在局限性。Holland 等人 [?] 指出, 许多匿名化评估方法可能给用户带来“虚假的隐私感”, 因为它们未能充分考虑实际攻击场景下的威胁。研究者提出了更可靠的评估方法论, 强调需要在真实威胁模型下通过对抗性测试来验证匿名化效果。

差分隐私 (Differential Privacy) 作为一种可证明的隐私保护框架, 为匿名性度量提供了新的思路。NetShaper[?] 将差分隐私应用于网络侧信道防护, 通过流量整形技术提供严格的隐私保证, 展示了理论隐私保证在实际系统中的应用潜力。

2.1.2 威胁模型

匿名网络面临的威胁主要包括:

被动攻击者: 能够观察网络流量但不主动干预。典型攻击包括流量分析、时序分析等。

主动攻击者: 能够修改、延迟或丢弃数据包。例如, 通过选择性丢包进行标记攻击。

全局对手: 能够观察整个网络的流量。这是最强的威胁模型, 许多匿名系统在此模型下无法提供安全保证。

2.2 主要匿名技术

2.2.1 洋葱路由 (Onion Routing)

洋葱路由是一种低延迟匿名通信技术, 其代表性实现是 Tor 网络 [3]。客户端选择一条由多个中继节点组成的电路, 对消息进行多层加密 (类似洋葱的层次结构)。每个中继节点剥离一层加密, 并将消息转发给下一跳, 直到到达目的地。这种设计使得单个节点无法同时知道消息的来源和目的地。

PoPETs 2024 的研究 [?] 提出了针对全局对手的可证明安全洋葱路由框架, 通过形式化方法明确了在全局监控下洋葱路由的安全性边界。Sphinx 数据包格式 [?] 作为洋葱路由的底层密码学原语, 其安全性分析对于确保整个系统的正确性至关重要。

2.2.2 Mix 网络 (Mix Networks)

Mix 网络由 Chaum 于 1981 年提出 [2], 是匿名通信的奠基性技术。Mix 节点收集一批消息, 对每条消息进行解密, 然后以随机顺序转发, 从而打破消息的可链接性。通过多跳 Mix 节点, 即使部分节点被攻破, 仍能保证一定程度的匿名性。

近年来, Mix 网络研究主要集中在性能优化和安全性增强:

延迟优化: LARMix[?] 提出了延迟感知路由策略, 通过自适应路由算法根据网络状态动态调整路由策略, 在保持强匿名性的同时将端到端延迟降低了 40-60%。

鲁棒性增强: Rabbit-Mix[?] 使用代数混合技术, 在诚实多数服务器假设下实现了 100% 的消息投递率和强鲁棒性, 是首个在客户端-服务器模型下同时实现鲁棒性和完全消息投递的实用匿名广播系统。

流量混合策略: Beta 混合 [?] 提出了针对不同延迟特性流量的混合策略, 在保持低延迟的同时提供 stronger 的匿名性保证。

安全性验证: Dreier 等人 [7] 开发了自动化工具, 用于发现 Mix 网络协议中的微妙攻击, 成功发现了多个已部署协议中的未知漏洞, 为协议设计提供了安全性验证手段。

2.2.3 其他匿名技术

Dining Cryptographers 网络 (DC-Nets): Chaum 于 1988 年提出 [8], 通过多方安全计算实现信息论安全的匿名广播。DC 网络提供了最强的匿名性保证, 但存在可扩展性和碰撞处理问题。

Crowds: 基于随机转发的匿名技术, 用户随机选择其他用户作为代理转发请求。

匿名凭证: 允许用户在不泄露身份的情况下证明某些属性, 广泛应用于电子投票、匿名认证等场景。

2.3 技术对比与发展趋势

2.3.1 技术对比

不同匿名技术在安全性、性能和适用场景上各有特点：

- **Mix 网络**：提供强匿名性保证，但延迟较高，适合电子邮件等非实时通信。
- **洋葱路由**：牺牲部分匿名性以换取低延迟，适合 Web 浏览等交互式应用。
- **DC-Nets**：提供信息论安全，但可扩展性差，适合小规模高安全需求场景。

2.3.2 发展趋势

性能与安全的平衡：当前研究致力于在保持强匿名性的同时降低延迟。LARMix 和 Beta 混合等工作展示了通过智能路由和流量混合策略实现这一目标的可能性。

可证明安全性：形式化方法被越来越多地应用于匿名协议的设计和验证，确保协议在特定威胁模型下的安全性。

新兴应用场景：移动端匿名通信 [9]、区块链隐私保护 [?] 等新兴应用推动了匿名技术的发展和适配。

差分隐私的融合：将差分隐私与传统匿名技术结合，为匿名通信提供更强的理论保证。

2.4 本章小结

本章介绍了匿名网络的核心概念、主要技术及其发展趋势。Mix 网络和洋葱路由作为两种主要的匿名技术，在安全性和性能上各有权衡。近年来的研究在延迟优化、鲁棒性增强、安全性验证等方面取得了重要进展。这些技术为下一章 Tor 网络的深入分析奠定了基础。

3 Tor 网络攻防技术

Tor (The Onion Router) 是当前部署规模最大、研究最充分的低时延匿名通信系统之一。自第二代洋葱路由系统被提出以来，Tor 逐步形成了由目录权威、志愿者中继、客户端、出口策略、洋葱服务与可插拔传输共同构成的复杂匿名通信生态 [3, 10]。从安全研究视角看，Tor 并非单一密码协议，而是一个同时受到密码学设计、互联网路由、流量统计学习、系统资源管理与审查对抗共同影响的大规模网络系统。因此，围绕 Tor 的攻防研究也呈现出明显的多层化特征：攻击侧从早期的节点控制与流量关联，发展到深度学习网站指纹、AS/BGP 级观测、洋葱服务会话关联、带宽膨胀和目录共识破坏；防御侧则从链路层协议加固、守卫节点策略和目录共识机制，扩展到流量填充、路由感知路径选择、隐私保护测量、抗审查传输和面向洋葱服务的性能优化。本节按照“架构基础-攻击演进-防御对抗-态势分析”的逻辑，对 Tor 网络攻防技术进行系统化梳理，并为后续讨论匿名网络与僵尸网络隐匿通信之间的关系提供技术基础。

3.1 Tor 网络架构

3.1.1 系统组成与节点角色

Tor 的思想源于一代洋葱路由。Syverson、Goldschlag 与 Reed 提出的匿名连接模型已经奠定了“发送方构造多层加密洋葱、每个中继只剥离一层并获得下一跳”的基本范式 [11]。Dingledine 等人提出的 Tor 则在此基础上完成了面向互联网部署的系统化重构：其核心目标不是提供绝对意义上的不可追踪性，而是在可接受时延和带宽开销下，使任一单点观察者难以同时获得通信双方身份 [3]。这种设计决定了 Tor 本质上属于低时延匿名通信系统，适合 Web 访问、即时通信和一般 TCP 应用，但并不承诺抵御能够同时观察全网入口与出口流量的全局被动攻击者。

Tor 网络由三类基本实体组成。第一类是**客户端**，负责获取目录共识、选择路径、建立链路并发起应用流量。第二类是**中继节点**，根据其在路径中的位置可分为守卫节点 (Guard)、出口节点 (Exit) 和中间节点 (Middle Relay)。守卫节点直接连接客户端，能够看到用户 IP 地址但不知道最终访问目标；出口节点负责将流量发送至公网目标，能够看到目的站点及未加密应用层内容但不知道用户真实地址；

中间节点只知道前后两跳，用于切断入口与出口之间的直接关系。第三类是**目录基础设施**，包括目录权威与目录缓存。目录权威周期性投票生成网络状态共识，发布中继身份、公钥摘要、地址、端口、带宽权重及 Guard、Exit、HSDir、BadExit 等标志位，是客户端进行路径选择和抵御大规模 Sybil 渗透的基础 [10]。

3.1.2 核心协议：目录共识、链路构建与洋葱加密

Tor 客户端在通信前首先下载并验证目录共识。共识文件给出了当前可用中继及其权重，客户端据此按照带宽加权、角色约束、出口策略和守卫节点策略选择一条典型的三跳路径。随后客户端采用增量式链路构建机制建立匿名通道：先与第一跳守卫节点完成认证密钥交换，再通过已经建立的前缀链路向第二跳、第三跳逐步发送扩展请求，使每个中继只获知自身相邻节点，而无法恢复完整路径 [3, 10]。这一 *telescoping construction* 机制同时保证了路径隐私与每跳密钥独立性。

Tor 的密码学结构可以概括为“非对称握手建立每跳密钥，对称加密承担高频数据转发”。在链路创建阶段，客户端分别与链路上的每个中继协商独立的会话密钥；在数据传输阶段，应用数据被切分为固定大小的信元并进行多层对称加密。客户端发送方向上，数据依次使用出口、中间、守卫三跳密钥进行嵌套加密；沿路径转发时，每个中继只解开属于自己的一层并根据内部头部信息转发给下一跳。反向传输时，出口、中间、守卫依次增加加密层，客户端最终逐层解开。固定大小信元、多路复用 TCP 流和端到端完整性校验共同降低了简单包长指纹和标签攻击风险，但并不能消除数据包方向、突发结构、时序间隔与连接持续时间等元数据泄露。

3.1.3 洋葱服务与真实网络测量

除访问公网服务外，Tor 还支持**洋葱服务**（Onion Service）。洋葱服务允许服务端隐藏自身 IP 地址，并通过引入点与汇合点完成客户端和服务端的匿名连接。与普通出口链路相比，洋葱服务通常需要客户端侧三跳链路与服务端侧三跳链路共同参与，路径更长、交互轮次更多，因此在延迟、吞吐和可用性上面临更大压力。Winter 等人通过访谈、问卷和 .onion 查询数据研究发现，用户对洋葱服务的心理模型并不完整，对地址发现和站点认证机制存在明显不满，同时现实中还存在大量相似洋葱地址和钓鱼风险 [12]。这说明洋葱服务的安全问题不仅是协议问题，也包含可用性、身份认证和用户认知问题。

对真实 Tor 网络的理解依赖隐私保护测量。Mani 等人基于 PrivCount 和 Private Set-Union Cardinality 对 Tor 进行测量，发现 Tor 日均用户规模可能显著高于传统估计，并观察到大量失败的洋葱地址查询 [13]。该类工作的重要意义在于：Tor 研究不能只停留在协议规范或小规模实验网络中，而必须在不伤害用户隐私的前提下理解真实流量、真实服务和真实攻击面。后续网站指纹、AS 级对手、洋葱服务性能和目录基础设施安全研究，均以这种测量基础为重要前提。

3.2 攻击技术分类与演进

针对 Tor 的攻击可按照攻击者观测面和攻击目标划分为四类：第一类是位于客户端侧或局部链路上的流量分析攻击，典型代表是网站指纹；第二类是同时观测入口侧与出口侧的去匿名化攻击，包括端到端流关联、DNS 增强关联和 AS/BGP 级攻击；第三类是面向洋葱服务的服务发现、可用性和会话关联攻击；第四类是针对 Tor 生态基础设施的攻击，包括拒绝服务、带宽测量操纵和目录共识破坏。

3.2.1 流量分析攻击：Website Fingerprinting 的深度学习化

网站指纹攻击（Website Fingerprinting, WF）试图在不破解 Tor 加密内容的情况下，仅利用包方向、突发长度、时间间隔和连接持续时间等元数据识别用户访问的网站或页面。2018 年前后，WF 研究发生了从手工特征工程向深度学习的转变。Sirinam 等人提出 Deep Fingerprinting (DF)，使用卷积神经网络直接学习 Tor 访问轨迹中的方向序列特征，在未防御流量和部分轻量级填充防御下取得了远高于传统方法的准确率 [14]。这一结果表明，固定大小信元只能削弱单包长度泄露，无法消除流量突发结构中蕴含的站点特征。

随后研究进一步关注模型的数据效率和特征完整性。Bhat 等人提出 Var-CNN，引入膨胀因果卷积和残差结构以捕捉长程时序依赖，并将自动学习特征与统计特征融合，证明深度 WF 攻击在低数据场景下仍具有较强能力 [15]。Rahman 等人的 Tik-Tok 则系统证明了时序信息并非噪声，而是与方向特

征互补的重要信号；其方向-时序融合表示在未防御 Tor、WTF-PAD 和洋葱站点流量上均显著提升识别能力 [16]。到 2024 年，Zhao 等人提出 Oscar，将问题从“识别网站”推进到“识别同一网站内部具体网页”，通过多标签度量学习处理多页面混合和细粒度网页差异，在大规模监控页与非监控页数据集上显著提升 Recall@5 [5]。这表明 Tor 流量分析的前沿已经从粗粒度站点分类转向开放世界、多标签、细粒度和跨时间泛化。

3.2.2 去匿名化攻击：流关联、DNS 泄露与 AS 级对手

当攻击者能够同时观察客户端到守卫节点的入口侧流量和出口节点到目的站点的出口侧流量时，攻击目标便从“用户访问了哪类网站”升级为“某个用户是否正在访问某个具体目标”。Nasr 等人提出 DeepCorr，利用深度学习模型学习 Tor 流量在多跳转发中的噪声和扰动模式，从而对入口流和出口流进行端到端相关性判断 [17]。该工作的重要性在于，它降低了流关联攻击对精心设计统计指标的依赖，说明中等规模多点观察者也可能借助数据驱动模型提升去匿名化能力。

DNS 路径进一步扩大了流关联攻击的观测面。Greschbach 等人的 DefecTor 研究指出，Tor 出口节点对公共 DNS 解析器的选择存在集中化现象，攻击者若能观察出口 DNS 请求，便可将 DNS 信息与客户端侧网站指纹结合，从而显著提升关联攻击效果 [18]。该工作提醒我们，Tor 的匿名性不仅取决于 Tor 覆盖网络本身，还受出口侧 DNS 解析、目的站点部署和互联网基础设施集中化影响。

更底层的威胁来自 AS 级和 BGP 级对手。AS 级攻击者不需要控制 Tor 中继，只需位于客户端-守卫路径和出口-目的路径的共同自治系统上，便可能被动关联两端流量。Sun 等人提出 Counter-RAPTOR，系统分析主动 BGP 前缀劫持对 Tor 匿名性的影响，说明攻击者可通过路由操纵使自身出现在入口或出口路径上 [19]。Gegenhuber 等人进一步利用 RIPE Atlas 长期测量不同国家客户端、Tor 入口路径和目标 AS 之间的关系，展示了 AS 级流量关联风险的地域差异和带宽集中化效应 [20]。因此，Tor 威胁模型已经从单纯的覆盖网络内部节点控制，扩展到互联网路由与自治系统层面的联合分析。

3.2.3 针对洋葱服务的攻击

洋葱服务因同时隐藏客户端和服务端位置，长期被视为 Tor 中更强的匿名通信形态，但其更长路径和更复杂握手也引入了新的攻击面。Winter 等人的用户研究表明，洋葱服务在地址发现、服务认证和用户信任方面存在天然脆弱性，攻击者可利用相似地址、过期链接和用户对 .onion 机制理解不足实施钓鱼或误导 [12]。这类问题并不直接破坏 Tor 密码协议，却会在实际使用中削弱匿名服务的安全性。

在网络层，Lopes 等人针对洋葱服务会话提出基于 Sliding Subset Sum 的流关联攻击，面向客户端与洋葱服务之间的会话流量进行过滤、时间对齐和滑动窗口匹配 [21]。与普通出口链路相比，洋葱服务路径更长、噪声更多、可能存在链路填充和多路复用，因此过去常被认为更难关联；该工作表明，只要攻击者在合适位置获得足够观测能力，仍可能通过高效统计匹配恢复会话关联关系。由此可见，洋葱服务安全不能仅依赖“路径更长”这一直觉，而需要结合流量填充、拥塞控制、服务发现和 DoS 防御进行系统设计。

3.2.4 基础设施攻击与最新研究进展

基础设施攻击关注的不是某条链路的瞬时匿名性，而是 Tor 网络维持可用性和可信路径选择所依赖的资源管理、带宽测量与目录共识。Jansen 等人提出的 Sniper Attack 揭示了 Tor 早期拥塞控制和传输队列设计可被用于低成本拒绝服务：恶意客户端或服务端通过操纵读取行为和 SENDME 机制，使目标中继积累大量未释放数据，最终耗尽内存并崩溃 [22]。该攻击的意义在于，DoS 不只是可用性威胁，还可能通过选择性排除守卫或出口节点改变用户路径选择，进而服务于去匿名化。相关实验大量依赖 Shadow 仿真框架，Jansen 等人关于 Tor 网络建模的方法论也成为后续安全评估的重要工具 [23]。

2023 年以来，研究焦点进一步转向带宽测量和目录共识机制。Sendner 等人提出 TorMult 带宽膨胀攻击，利用多个中继共享资源以及带宽测量流量可被识别的缺陷，使攻击者控制的节点在共识中获得高于真实能力的带宽权重，从而增加被选入用户链路的概率 [24]。这类攻击直接挑战了 Tor“按带宽加权选择路径”的基础假设。进一步地，Luo 等人针对目录协议提出短时 DDoS 破坏共识生成的研究，指出现有目录权威协议在网络同步假设上存在脆弱性，并提出基于部分同步模型的缓解方案 [25]。尽管该工作时长上已超出 2023–2025 窗口，但其揭示的方向代表了最新趋势：Tor 攻防正在从客户端流量层面扩展到目录、测量和共识协议本身。

3.3 防御技术与对抗

Tor 防御技术必须同时满足匿名性、性能、部署成本和兼容性约束。与高时延 Mix 网络不同, Tor 不能通过长时间批处理、强制重排序或大量固定速率填充来彻底隐藏流量时序, 否则会破坏 Web 浏览等交互式应用体验。因此, Tor 防御研究的核心矛盾是: 如何在有限带宽和低时延约束下, 最大程度降低攻击者从元数据中提取稳定特征的能力。

3.3.1 流量混淆技术

针对网站指纹攻击, 防御思路主要包括填充、延迟、突发整形和对抗扰动。Holland 与 Hopper 提出 RegulaTor, 以下载流量速率衰减模型和上传/下载比例约束重塑网页加载轨迹, 并在预算范围内注入哑包, 从而降低 WF 分类器对突发形状的利用能力 [26]。其贡献不只在降低分类准确率, 更在于强调防御必须同时报告带宽开销、延迟开销和开放世界效果。Holland 等人的 DeTorrent 进一步代表了填充型防御研究向对抗式、可部署方向发展的趋势, 即在尽量不改变协议主体的条件下, 通过更精细的 padding 策略降低流量分析收益 [27]。

但是, 流量混淆存在天然上限。若防御过弱, 深度模型仍可利用剩余方向和时序模式; 若防御过强, 则会造成不可接受的带宽与延迟膨胀。更重要的是, 攻击者可以采用自适应训练, 将防御后的流量纳入训练集, 使静态规则防御迅速失效。因此, 当前更有前景的方向是将填充策略与真实网络状态、应用层加载阶段、拥塞控制和客户端部署环境结合起来, 形成动态、低开销、可更新的防御机制, 而不是依赖固定模式的离线混淆。

3.3.2 协议层防御

协议层防御主要包括守卫节点策略、路由感知路径选择、目录共识加固和隐私保护测量。守卫节点机制通过长期固定少量入口节点, 降低用户在频繁随机选择入口时遇到恶意守卫的概率; 目录权威和共识签名则通过多方投票降低单点目录投毒风险 [10]。针对 AS/BGP 级攻击, Counter-RAPTOR 提出将 AS 弹性纳入守卫选择, 并结合 BGP 异常监测对路由劫持进行检测 [19]。这一思路说明, Tor 协议层防御不能只优化覆盖网络内部路径, 还必须考虑底层互联网路径是否会把入口侧和出口侧同时暴露给同一观察者。

面对基础设施攻击, 防御重点则转向资源约束和共识鲁棒性。Sniper Attack 之后, Tor 需要在拥塞控制、传输队列和流控窗口上限制攻击者可放大的资源消耗 [22]; TorMult 之后, 带宽权威测量需要更强的抗操纵能力, 避免共享资源、测量流量识别和策略性丢弃用户流量造成路径选择偏斜 [24]。目录协议方面, 部分同步模型和更稳健的投票恢复机制可增强目录权威在短时 DDoS 或网络分区下的可用性 [25]。这些研究表明, Tor 匿名性不仅依赖密码学正确性, 还依赖测量系统、共识协议和网络资源治理的可信性。

3.3.3 新兴防御技术

新兴防御主要集中在两条路径: 一是提升洋葱服务和 Tor 传输性能, 二是增强抗审查能力。在性能方面, DarkHorse 提出基于 UDP 的数据传输框架, 试图缓解洋葱服务中 TCP-over-TCP、长路径和多轮握手带来的高延迟问题 [28]。该类方案的挑战在于, UDP 带来的乱序、丢包和路径语义变化需要与 Tor 现有链路抽象、可靠性机制和匿名性假设重新协调。

在抗审查方面, Tor 长期依赖可插拔传输将 Tor 流量伪装成更难被识别或更高封锁代价的协议流量。MacMillan 等人对 Snowflake 的研究表明, 基于 WebRTC 的抗审查传输虽然能利用大量临时代理提高可达性, 但其握手特征和流量行为仍可能与真实 WebRTC 应用存在可区分差异 [29]。Sun 与 Shmatikov 提出的差异降级攻击进一步说明, 审查者不一定需要准确分类流量, 只需制造某些网络退化条件, 使规避系统性能下降而正常应用仍可接受, 即可形成低成本封锁 [30]。Vilalonga 等人的 Obscura 则代表了后续方向: 将流量封装进 WebRTC 媒体流, 结合瞬时代理和可靠传输层, 试图同时抵抗深度包检测、代理枚举和差异降级 [31]。总体看, 抗审查研究已经从“让 Tor 不像 Tor”转向“让封锁 Tor 的代价接近封锁正常应用”。

3.4 攻防态势分析

综合现有文献, Tor 攻防态势呈现出四个趋势。第一, **攻击能力从规则化走向数据驱动**。DF、Var-CNN、Tik-Tok 和 Oscar 表明, 深度学习已经能够从加密流量的方向、时序和突发结构中自动提取稳定特征 [14, 15, 16, 5]; Shadbeh 等人的真实开放世界评估进一步说明, 网站指纹并非纯粹实验室威胁, 而可能在接近真实守卫观察者的条件下保持较高有效性 [32]。这迫使防御研究必须从封闭世界准确率转向开放世界精度、召回率、基准率、跨时间泛化和真实部署开销。

第二, **去匿名化攻击面从 Tor 覆盖网络内部扩展到底层互联网**。DeepCorr 证明入口-出口流关联可由深度模型增强 [17], DefecTor 说明 DNS 解析基础设施会扩大出口侧观测面 [18], Counter-RAPTOR 和后续 AS 级测量则表明 BGP 路由、自治系统路径和中继带宽集中度都会改变用户实际暴露风险 [19, 20]。因此, Tor 匿名性不能仅由三跳链路结构解释, 而必须放入互联网路由、公共解析器和跨域流量监测的环境中评估。

第三, **基础设施安全成为 Tor 生态的关键瓶颈**。Sniper Attack、TorMult 和目录 DDoS 研究分别指向资源管理、带宽测量和目录共识三个核心支柱 [22, 24, 25]。攻击者若能影响这些基础设施, 即使不破解任何密码原语, 也可能通过改变路径选择概率、降低网络可用性或迫使用户连接恶意中继来削弱匿名性。这一趋势对于僵尸网络研究尤其重要: 僵尸网络若利用 Tor 作为 C2 隐匿层, 其稳定性同样依赖 Tor 中继生态和目录系统; 反过来, 针对 Tor 基础设施的攻击也可能影响恶意流量隐匿与防御监测的平衡。

第四, **防御研究越来越强调可部署性而非单一安全指标**。RegulaTor 和 DeTorrent 体现了低开销抗 WF 防御的工程约束 [26, 27], Counter-RAPTOR 体现了路由安全与匿名熵之间的权衡 [19], DarkHorse 和 Obscura 则分别从性能和抗审查角度探索 Tor 系统边界 [28, 31]。总体而言, Tor 未来演进很可能不会依赖某个单一突破, 而是由路径选择、拥塞控制、流量填充、目录共识、抗审查传输和隐私保护测量的协同优化共同推动。

由此可见, Tor 网络的核心矛盾始终是低时延可用性与强匿名性之间的张力。攻击者只需在入口观测、出口观测、路由操控、流量统计或基础设施治理中的某一环节取得优势, 即可显著削弱匿名性; 防御者则必须在不牺牲可用性和开放部署生态的前提下, 同时约束多类攻击面。这种不对称性决定了 Tor 仍将是匿名通信、安全测量和攻防博弈研究中的长期核心对象, 也为后续分析僵尸网络如何借助匿名网络隐藏指挥控制、以及安全防御方如何在不侵犯正常用户隐私的条件下识别滥用行为, 提供了直接的理论与技术铺垫。

4 僵尸网络匿名化与检测

僵尸, 桀桀桀

5 讨论

在此讨论研究发现。

6 结论

在此撰写结论。

参考文献

- [1] S. Sasy and I. Goldberg, “Sok: Metadata-protecting communication systems,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [2] D. L. Chaum, “Untraceable electronic mail, return addresses, and digital pseudonyms,” *Communications of the ACM*, vol. 24, no. 2, pp. 84–90, 1981.
- [3] R. Dingledine, N. Mathewson, and P. Syverson, “Tor: The second-generation onion router,” 2004.

- [4] M. Shen, K. Ji, Z. Gao, Q. Li, L. Zhu, and K. Xu, “Subverting website fingerprinting defenses with robust traffic representation,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 607–624.
- [5] X. Zhao, X. Deng, Q. Li, Y. Liu, Z. Liu, K. Sun, and K. Xu, “Towards fine-grained webpage fingerprinting at scale,” in *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*, 2024, pp. 423–436.
- [6] R. Jansen, R. Wails, and A. Johnson, “A measurement of genuine tor traces for realistic website fingerprinting,” in *International Conference on Passive and Active Network Measurement*. Springer, 2026, pp. 277–293.
- [7] J. Dreier, P. Lafourcade, and D. Mahmoud, “Shaken, not stirred-automated discovery of subtle attacks on protocols using {Mix-Nets},” in *33rd USENIX Security Symposium (USENIX Security 24)*, 2024, pp. 3135–3150.
- [8] D. Chaum, “The dining cryptographers problem: Unconditional sender and recipient untraceability,” *Journal of cryptology*, vol. 1, no. 1, pp. 65–75, 1988.
- [9] D. Hugenroth and A. R. Beresford, “Powering privacy: On the energy demand and feasibility of anonymity networks on smartphones,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 5431–5448.
- [10] The Tor Project, “Tor specifications,” <https://spec.torproject.org/index.html>, online; accessed 2026-05-28.
- [11] P. F. Syverson, D. M. Goldschlag, and M. G. Reed, “Anonymous connections and onion routing,” in *Proceedings. 1997 IEEE Symposium on Security and Privacy (Cat. No. 97CB36097)*. IEEE, 1997, pp. 44–54.
- [12] P. Winter, A. Edmundson, L. M. Roberts, A. Dutkowska-Żuk, M. Chetty, and N. Feamster, “How do tor users interact with onion services?” in *27th USENIX Security Symposium (USENIX Security 18)*, 2018, pp. 411–428.
- [13] A. Mani, T. Wilson-Brown, R. Jansen, A. Johnson, and M. Sherr, “Understanding tor usage with privacy-preserving measurement,” in *Proceedings of the Internet Measurement Conference 2018*, 2018, pp. 175–187.
- [14] P. Sirinam, M. Imani, M. Juarez, and M. Wright, “Deep fingerprinting: Undermining website fingerprinting defenses with deep learning,” in *Proceedings of the 2018 ACM SIGSAC conference on computer and communications security*, 2018, pp. 1928–1943.
- [15] S. Bhat, D. Lu, A. Kwon, and S. Devadas, “Var-cnn: A data-efficient website fingerprinting attack based on deep learning,” *arXiv preprint arXiv:1802.10215*, 2018.
- [16] M. S. Rahman, P. Sirinam, N. Mathews, K. G. Gangadhara, and M. Wright, “Tik-tok: The utility of packet timing in website fingerprinting attacks,” *arXiv preprint arXiv:1902.06421*, 2019.
- [17] M. Nasr, A. Bahramali, and A. Houmansadr, “Deepcorr: Strong flow correlation attacks on tor using deep learning,” in *Proceedings of the 2018 ACM SIGSAC conference on computer and communications security*, 2018, pp. 1962–1976.
- [18] B. Greschbach, T. Pulls, L. M. Roberts, P. Winter, and N. Feamster, “The effect of dns on tor’s anonymity,” *arXiv preprint arXiv:1609.08187*, 2016.
- [19] Y. Sun, A. Edmundson, N. Feamster, M. Chiang, and P. Mittal, “Counter-raptor: Safeguarding tor against active routing attacks,” in *2017 IEEE symposium on security and privacy (SP)*. IEEE, 2017, pp. 977–992.

- [20] G. K. Gegenhuber, M. Maier, F. Holzbauer, W. Mayer, G. Merzdovnik, E. Weippl, and J. Ullrich, “An extended view on measuring tor as-level adversaries,” *Computers & Security*, vol. 132, p. 103302, 2023.
- [21] D. Lopes, J.-D. Dong, P. Medeiros, D. Castro, D. Barradas, B. Portela, J. Vinagre, B. Ferreira, N. Christin, and N. Santos, “Flow correlation attacks on tor onion service sessions with sliding subset sum.” in *NDSS*, 2024.
- [22] R. Jansen, F. Tschorsch, A. Johnson, and B. Scheuermann, “The sniper attack: Anonymously deanonymizing and disabling the tor network,” 2014.
- [23] R. Jansen, K. S. Bauer, N. Hopper, and R. Dingledine, “Methodically modeling the tor network.” in *CSET*, 2012.
- [24] C. Sendner, J. Stang, A. Dmitrienko, R. Wijewickrama, and M. Jadliwala, “Tormult: introducing a novel tor bandwidth inflation attack,” *arXiv preprint arXiv:2307.08550*, 2023.
- [25] Z. Luo, J. Zhang, A. Neerati, and A. Kate, “Five minutes of ddos brings down tor: Ddos attacks on the tor directory protocol and mitigations,” in *Proceedings of the 21st European Conference on Computer Systems*, 2026, pp. 1314–1329.
- [26] J. K. Holland and N. Hopper, “Regulator: A straightforward website fingerprinting defense,” *arXiv preprint arXiv:2012.06609*, 2020.
- [27] J. K. Holland, J. Carpenter, S. E. Oh, and N. Hopper, “Detorrent: An adversarial padding-only traffic analysis defense,” *arXiv preprint arXiv:2302.02012*, 2023.
- [28] M. W. Al Azad, H. Zahan, S. U. Taki, and S. Mastorakis, “Darkhorse: A udp-based framework to improve the latency of tor onion services,” in *2023 IEEE 48th Conference on Local Computer Networks (LCN)*. IEEE, 2023, pp. 1–6.
- [29] K. MacMillan, J. Holland, and P. Mittal, “Evaluating snowflake as an indistinguishable censorship circumvention tool,” *arXiv preprint arXiv:2008.03254*, 2020.
- [30] Z. Sun and V. Shmatikov, “Differential degradation vulnerabilities in censorship circumvention systems,” *arXiv preprint arXiv:2409.06247*, 2024.
- [31] A. Vilalonga, K. Gallagher, J. S. Resende, and H. Domingos, “Obscura: Enabling ephemeral proxies for traffic encapsulation in webrtc media streams against cost-effective censors,” *Proceedings on Privacy Enhancing Technologies*, 2026.
- [32] M. Shadbeh, K. Khajavi, and T. Wang, “Reality check for tor website fingerprinting in the open world,” *arXiv preprint arXiv:2603.07412*, 2026.